

CTF Writeup: WebBasics - OTP

Challenge Name: WebBasics - OTP

Category: Web

Points: 481

Author: Senpai

Flag: `SK-CERT{y0u_h4v3_f0und_4dmin_s3cr37_70k3n}`

Challenge Description

The challenge features a secure, certified application designed for generating daily tokens from secret seeds. The objective is to find the specific seed that generates the flag.

1. Initial Reconnaissance

- **Application Interface:** The site features a clean login/register page built with Materialize CSS.
- **Authentication:** A new account named "roots" was registered to access the internal system.
- **Token Dashboard:** Upon logging in, the dashboard displays a "daily token" (a 64-character SHA-256 looking hex string) and a link to the user's profile.
- **User Context:** The registered user "roots" was assigned user ID 179, accessible via `/profile/179`.

2. Vulnerability Discovery

Profile Manipulation

Navigating to the profile page revealed that the **Secret Initializator (seed)** was both visible and editable. Users can modify their password and secret seed via a POST form. This suggests the token generation logic follows a formula such as:

```
token = hash_function(secret_seed + current_date)
```

IDOR (Insecure Direct Object Reference)

Testing for authorization flaws, the URL was manually changed from `/profile/179` to `/profile/1`. The application failed to restrict access, successfully loading the profile of user ID 1, who was identified as the **admin**.

- **Admin Username:** admin
- **Admin Secret Seed:** `a95aa045a8bf5e502ee2541dd2a00925e2e825eacbbc22dadfb4ba027094dbf0`

3. The Attack

The exploitation process involved the following steps:

1. Logged in as the low-privileged user (roots, ID 179).
2. Accessed the admin profile via `/profile/1` and copied the admin's secret seed.
3. Returned to the personal profile at `/profile/179` and replaced the original seed with the admin's seed.
4. Navigated back to the main dashboard (`/`).

Result: The application generated a new "Today Token" based on the admin's seed, which revealed the flag:

`SK-CERT{y0u_h4v3_f0und_4dmin_s3cr37_70k3n}`

4. Root Cause Analysis

- **IDOR Vulnerability:** The application trusted the ID parameter in the URL and did not perform ownership checks on profile data.
- **Insecure Design:** Authenticated users were permitted to modify their own secret seeds, which directly controlled the token output.
- **Lack of Validation:** There was no rate limiting or validation on the `secret_init` field.

5. Lessons Learned

- Always implement strict ownership checks on user profiles.
- Sensitive security parameters like seeds should never be editable by standard users.
- Frequently test for IDOR vulnerabilities on any numeric ID parameters in URLs.
- Daily tokens are only as secure as the seeds they are derived from; if a seed can be controlled, the token can be spoofed.